BOR-BOX Tier-0 False-Positive Measurement — Program Plan

Project: BOR-BOX DNS security middlebox (university workshop, TAU) **Goal:** Identify false positives produced by each Tier-0 (stateless, per-packet) rule on real resolver traffic, and compute a defensible FP percentage per rule. **Dataset:** Žiža, Tadić & Vuletić, "DNS Exfiltration Dataset" v3, Mendeley Data, DOI 10.17632/c4n7fckkz3.3 — ~35M DNS request records logged at the client-facing side of a national ISP's production recursive resolver over ~26 hours, IPs anonymized with an injective mapping, real query names preserved, injected exfiltration traffic (Iodine, DNSExfiltrator) labeled.

---

1. Objective and scope

The program answers one question per rule: *of the legitimate DNS queries a production resolver actually receives, what fraction would this rule divert to the LIMIT queue?*

Scope is restricted to the rules whose predicate is a function of the query name and per-client timing, because the dataset is a request-name log: it contains no responses, no header bytes, and no additional sections. Response-side rules (NXNS/NRDelegation counts, CacheFlush ANCOUNT/NSCOUNT, KeyTrap, NSEC3 iterations, RRSet bloating, TuDoor's QDCOUNT conditions, SIG(0)) are explicitly out of scope here and are handled by the separate re-resolution harness that replays this dataset's name distribution live and captures wire-format responses.

Because BOR-BOX rate-limits rather than drops, a false positive costs latency, not resolution. The output of this program is therefore not a pass/fail verdict but a calibrated cost estimate: how many legitimate queries per million get slowed, and by whom.

2. Definitions

False positive (FP). A query record that (a) carries no exfiltration label in the dataset, and (b) matches a LIMIT rule under the evaluation semantics defined in §5. The unlabeled remainder of the dataset is treated as benign ground truth (the standard peacetime assumption; see §8 for the caveat).

Applicable population (denominator). For each rule, the set of records the rule actually evaluates. For the QNAME rules under test here, every query record is applicable, so the denominator is the full benign record count N. The definition is stated per rule anyway, because the response-side harness will need class-restricted denominators (e.g., only DNSKEY responses for the KeyTrap rule), and the two reports must use the same vocabulary.

FP rate. FP count divided by applicable benign population, reported three ways: percentage, absolute FPs per million queries, and projected false-LIMIT decisions per second at a reference load (we will state results at 10k and 50k qps).

3. Rules under test

ID	Source slide	Rule (as deployed)	Testability
R1	Water torture — Takeuchi rule 1	`IF IN QUESTION THE QNAME is ^[a-zA-Z0-9]{8,}+\.[^.]+\.[^.]+\.$ LIMIT`	Full
R2	Water torture — Takeuchi rule 2	`IF IN QUESTION THE QNAME IS ^([^.]+\.){4,}[^.]+\.[^.]+\.$ LIMIT`	Full
R3	Water torture — Takeuchi rule 3	`IF IN QUESTION THE QNAME IS ^[^.]*[0-9][^.]*[a-z][^.]*[0-9][^.]*\. LIMIT`	Full
R4	"Important Notes" simplified variant	`IF IN QUESTION THE QNAME is ^[a-zA-Z0-9]{8,}\..+\.$ LIMIT`	Full
R5	CDN/cloud ALLOW list (11 rules)	`.*\.cloudfront\.net\.$ …` `.*\.azurefd\.net\.$ ALLOW`, evaluated before R1–R4	Full (as a system with R1–R4)
R6	TuDoor — QNAME condition only	`IF IN QUESTION THE QNAME IS (\.\.+) LIMIT`	Full
R7	TsuNAME / Kaminsky similarity	`IF IN HEADER EXACT EXCEPT txid LIMIT`	Proxy only: same-client same-QNAME sub-second repeat bursts as the legitimate-lookalike class. Reported separately and clearly marked as a bound, not a measurement

R1–R4 are each expected to have materially different FP populations (e.g., reversed-IPv4 DNSBL labels are all-digit and miss R3 but hit R2), which is precisely why rates are computed per rule and never pooled.

4. Data acquisition and preprocessing

1. **Download and freeze.** Fetch v3 from Mendeley, record file checksums, and pin the version in the repo. All results reference the frozen copy.

2. **Schema discovery.** Parse `dataset_description.txt` first and generate a column map. Confirm which columns hold: raw query name, client identifier, timestamp, query type (if present), and the exfiltration label. Nothing downstream is written until this map is checked in.
3. **Benign/malicious split.** Drop every labeled exfiltration row from the benign corpus before any counting — leaving them in silently converts true positives into inflated "false" positives. Keep the dropped rows in a separate file: they serve as a free true-positive check (§9).
4. **Canonicalization.** Define one normalization function used by both the harness and (verified against) the BOR-BOX engine: lowercase; ensure exactly one trailing dot (the deployed regexes anchor on `\.$`, so a dataset stored without trailing dots would silently zero every match); strip surrounding whitespace; leave punycode (`xn--`) labels as-is but count them, since IDN labels are a plausible FP niche worth a line in the report.
5. **Dataset profile.** Before any rule runs, emit a one-page profile: record count, unique QNAMEs, unique clients, label-count distribution, 2LD frequency head, NXDOMAIN-related fields if present, records per hour. This is the sanity anchor for everything after it and the evidence that the corpus is organic (Zipf head, DNSBL presence, diurnal shape).

5. Evaluation semantics

Two modes are computed in the same pass, because they answer different questions:

Independent mode. Each rule R1–R4, R6 is evaluated against every benign record in isolation. This yields the intrinsic FP rate of each pattern and is the number used to compare and tune individual regexes.

System mode. Rules are evaluated in deployment order with first-match-wins: the R5 ALLOW list first, then R1–R4/R6 in their configured order. A record's outcome is the action of the first matching rule. This yields the operational FP rate — what the box would actually do — and, by differencing against independent mode, quantifies exactly how much the ALLOW list buys. The report presents R1 three ways: raw, post-ALLOW residual, and the residual's composition. The hypothesis to test: the 11-entry CDN list removes a visible chunk but leaves a large residual dominated by 2LDs no static list anticipates (DNSBLs, telemetry, ad tech, regional CDNs) — which, if confirmed, is the empirical motivation for Tier-1.

6. Engine parity

The measurement is only valid if the harness matches what runs in the box. Three known hazards, each with a required mitigation:

1. **Regex dialect.** R1 uses a possessive quantifier (`{8,}+`). Python's `re` supports it only from 3.11; older interpreters raise, and "fixing" the pattern can change semantics. The harness must either link the same DFA engine the box uses, or pin Python ≥3.11 and

prove equivalence: compile both `{8,}+` and `{8,}` variants and assert identical match sets on the corpus (for these anchored patterns they should be identical; the assertion makes that a checked fact instead of an assumption).

2. **Match semantics.** The DFA path does anchored full-scan matching; Python distinguishes `match`/`search`/`fullmatch`. R3 is unanchored at the end — the harness must use search semantics for it and anchored semantics for R1/R2/R4. This is encoded per-rule in config, not left to convention.
3. **Golden tests.** A fixture of ~50 hand-labeled names (known hits, known misses, edge cases: exactly 8 chars, exactly 3 labels, trailing-dot variants, uppercase, empty-label names for R6) runs in CI against both the harness and the BOR-BOX engine via its normal packet path (Scapy-crafted queries through the box in the existing Docker testbed). Any divergence blocks a measurement run.

7. Pipeline architecture

Single streaming pass; nothing loads 35M rows into memory.

Stage 1 — reader: CSV stream, column map from §4, yields (client, ts, qname_raw, label). Stage 2 — normalize: canonicalization function; malformed rows counted and quarantined, never silently skipped. Stage 3 — split: labeled rows to the TP file; benign rows onward. Stage 4 — evaluate: compiled rule set applied per record; emits a per-record bitmask of independent matches plus the system-mode outcome. The bitmask makes every aggregate below derivable in the same pass. Stage 5 — aggregate: per rule — match count; per-2LD match counts (top-K heap); per-client match counts; hourly match counts; reservoir sample of ~200 matching QNAMEs for manual review. Stage 6 — report: machine-readable JSON of all aggregates plus a rendered summary (§9).

R7 runs as a separate keyed pass: per (client, qname) sliding window, count repeat events within a threshold Δt (parameter sweep: 100 ms, 500 ms, 1 s), report the fraction of benign traffic that would sit inside an "identical-except-txid" burst at each threshold. Output is labeled as an upper-bound proxy.

Performance target: full corpus in under 10 minutes on a laptop (35M rows through six compiled regexes is comfortably CPU-bound and parallelizable by file chunk if needed). Determinism requirement: fixed RNG seed for the reservoir samples so runs are reproducible.

8. Ground-truth policy and its limits

Everything unlabeled is treated as benign. Two known threats to that assumption, both handled by disclosure rather than silent correction: the corpus may contain real-world malicious traffic the collectors didn't label (any such traffic that matches a rule deflates the reported FP rate's honesty in our favor, so it is the conservative direction for us to acknowledge, not to exploit); and the manual review of the per-rule exemplar samples (§7,

stage 5) may surface matches that look genuinely malicious — these are recorded and reported as "disputed" rather than reclassified, because ad-hoc reclassification by the people being evaluated is how FP numbers get quietly cooked.

9. Validation checklist (run before results are believed)

1. **TP smoke test.** The labeled Iodine/DNSExfiltrator rows must trip R1/R4 at a high rate. If they don't, the harness or normalization is broken.
2. **Zero-suspicion rule.** Any rule reporting FP ≈ 0 on 35M organic queries triggers an investigation before it triggers a celebration — the default suspicion is a normalization or anchoring bug (most likely the trailing-dot mismatch).
3. **Golden tests green** (§6.3) on both engines.
4. **Row accounting.** reader rows = quarantined + labeled + benign; benign = sum over system-mode outcomes. Exact equality, checked every run.
5. **Cross-check on the secondary corpus.** Re-run R1–R4/R6 on the ~1M QNAMEs extracted from the GraphTunnel `normal/` crawl and on its `wildcard/` set. Rates are expected to differ from the ISP corpus (crawl vs organic); the wildcard set specifically stress-tests the water-torture rules. Divergence direction and magnitude go in the report as external validity evidence.

10. Outputs

1. **Per-rule results table:** FP%, FPs per million, projected false-LIMIT/s at 10k and 50k qps, independent vs system mode.
2. **Attribution tables:** top-20 2LDs by FP count per rule, top client concentration (does the FP mass come from a few clients — e.g., one mail server hammering DNSBLs — or from everyone), hourly FP profile.
3. **Exemplar appendix:** the reviewed sample of matching names per rule, with disputed entries flagged.
4. **ALLOW-list candidates:** ranked 2LD list generated from the attribution tables — the data-derived successor to the hand-written 11-entry CDN list, with the projected residual FP rate if adopted.
5. **Limitations section (mandatory in the writeup):** query-side rules only; single ISP, single 26-hour window, 2022 name mix; R7 is a proxy bound; benign-by-absence-of-label ground truth; response-side rules measured separately by the re-resolution harness.

11. Work plan

1. Download, freeze, schema map, dataset profile — 0.5 day.
2. Canonicalization + golden fixtures + engine-parity harness — 1 day (this is the step that protects every later number; do not compress it).

3. Streaming pipeline stages 1–6 — 1 day.
4. R7 proxy pass — 0.5 day.
5. Full runs, validation checklist, secondary-corpus cross-check — 0.5 day.
6. Report rendering + ALLOW-list candidate generation + writeup — 1 day.

Total ≈ 4.5 focused days, with step 2 as the critical path for credibility rather than speed.